

iscte

INSTITUTO
UNIVERSITÁRIO
DE LISBOA

Segurança em Redes de Computadores

Licenciatura em Tecnologias Digitais e Segurança da Informação

Prof. João Pedro Pavia

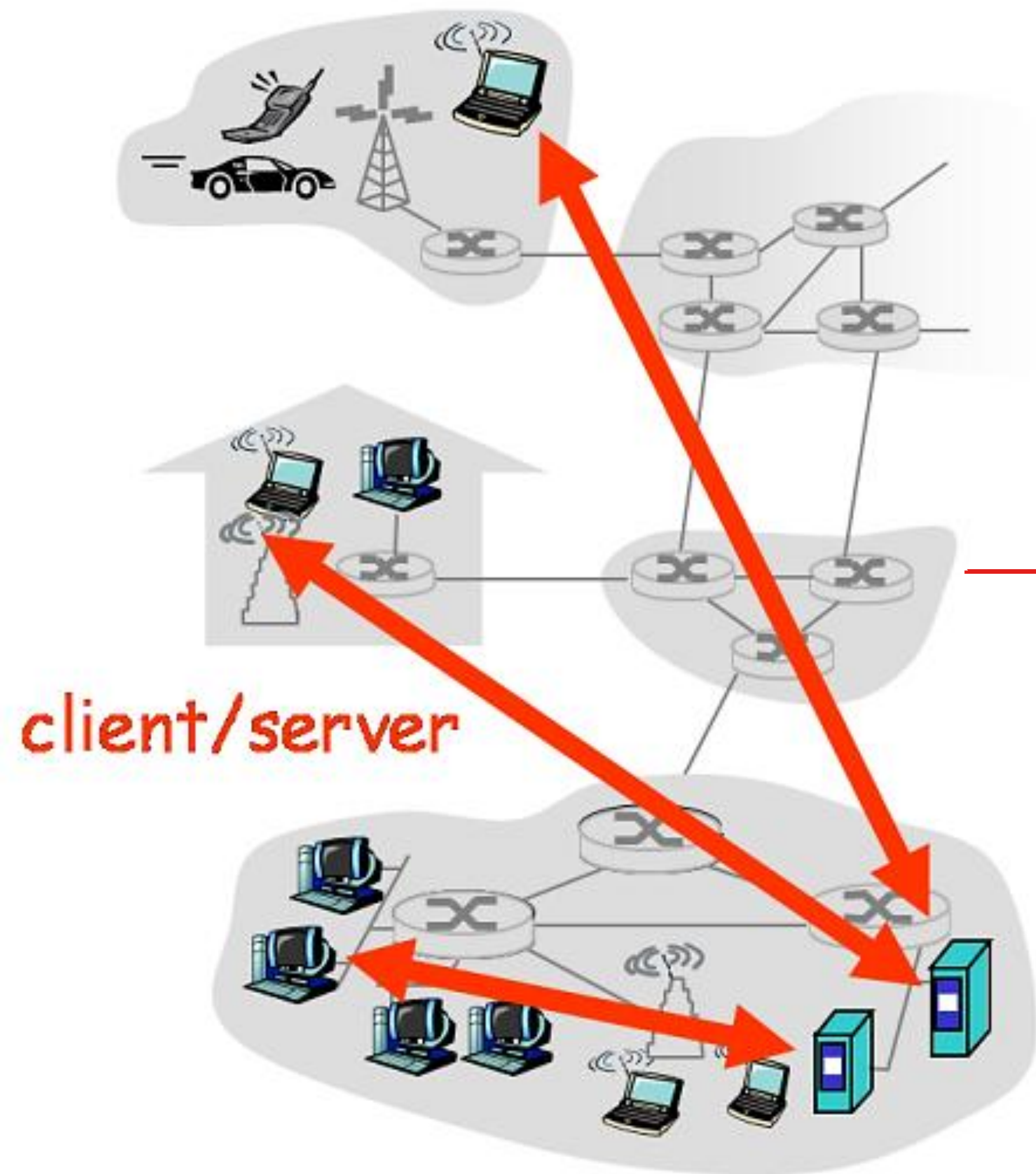
Ano letivo 2024/2025

Índice de Conteúdos

1. Segurança no nível da aplicação
2. Segurança do nível do DNS
3. Correio Eletrónico Seguro
4. Transferência Segura de Ficheiros

Camada de Aplicação

NESTA AULA O NOSSO
FOCO ESTARÁ AQUI



- A esmagadora maioria das aplicações que utilizamos apresentam uma arquitetura baseada no paradigma cliente-servidor.
- A máquina que atua como servidor tem tipicamente as seguintes características:
 - Sempre ligado;
 - IP Fixo.
- Por sua vez a máquina cliente comporta-se da seguinte forma:
 - Comunica diretamente com o servidor, só se ligando quando necessário;
 - IP dinâmico;
 - Não existe comunicação direta entre os clientes.

Diferenças entre as Aplicações de Servidor e Cliente

Servidor	Cliente
Começa em 1º lugar	Começa a seguir
Não precisa de saber que cliente contactar	Precisa de saber que servidor deverá contactar
Espera de forma passiva e arbitrária pelo contacto de um cliente	Inicia um contacto sempre que é necessária uma comunicação
Comunica com um cliente recebendo e enviando dados	Comunica com um servidor recebendo e enviando dados
Continua a correr após ter servido um cliente e espera por outro	Pode terminar a interação após ter interagido com o servidor

Características dos Protocolos de Aplicação

- Os protocolos de aplicação definem:
 - **Tipos de mensagens trocadas:** pedido e resposta;
 - **Sintaxe:** que campos existem e como são delineados;
 - **Semântica:** o que significa cada informação de cada campo;
 - **Regras de quando enviar e receber as mensagens.**
- Normalmente definidos em RFCs.

Aplicações e Requisitos (1/3)

- As aplicações têm necessidades em relação ao transporte dos dados
 - **Perda de dados (*data loss*)** - pode existir perda de dados em áudio mas não em transferência de ficheiros;
 - **Atraso (*delay*)** - comunicações interativas precisam de pouco atraso;
 - **Taxa de transferência (*throughput*)** - existem necessidades mínimas ou *best effort* (*elastic*);
 - **Segurança** - cifra de dados e integridade;
 - **Stream** - fluxo bidireccional de comunicação

Aplicações e Requisitos (2/3)

Application	Data loss	Throughput	Time Sensitive
file transfer	no loss	elastic	no
e-mail	no loss	elastic	no
Web documents	no loss	elastic	no
real-time audio/video	loss-tolerant	audio: 5kbps-1Mbps video: 10kbps-5Mbps	yes, 100's msec
stored audio/video	loss-tolerant	same as above	yes, few secs
interactive games	loss-tolerant	few kbps up	yes, 100's msec
instant messaging	no loss	elastic	yes and no

Aplicações e Requisitos (3/3)

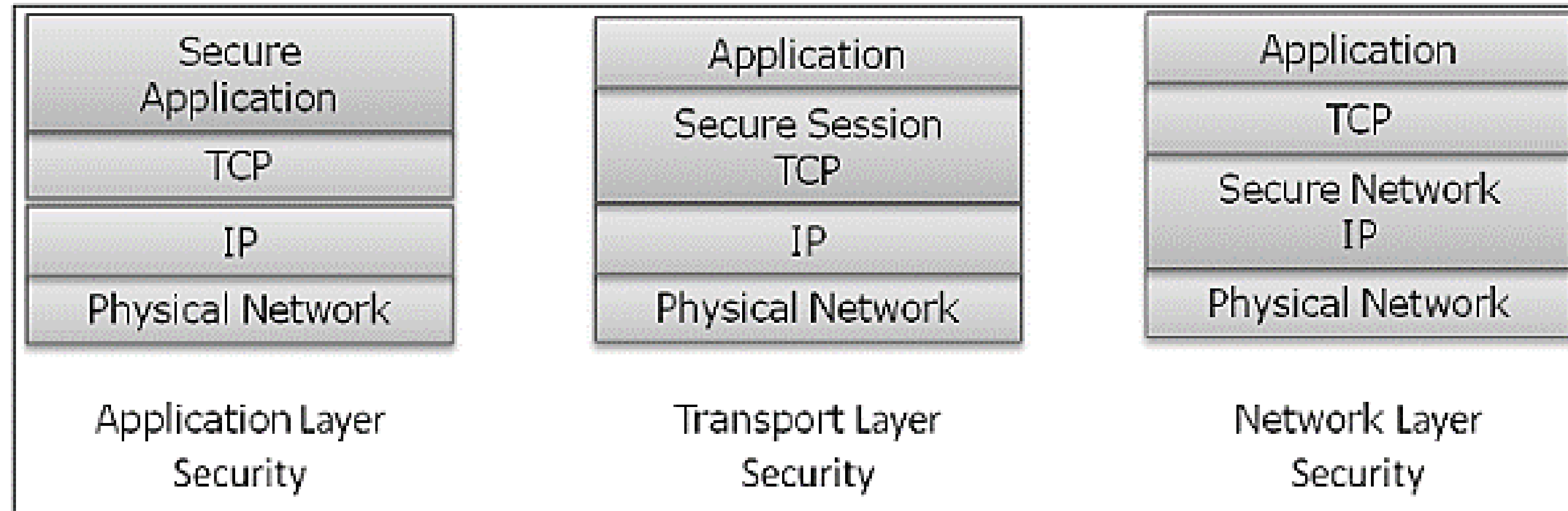
Application	Application layer protocol	Underlying transport protocol
e-mail	SMTP [RFC 2821]	TCP
remote terminal access	Telnet [RFC 854]	TCP
Web	HTTP [RFC 2616]	TCP
file transfer	FTP [RFC 959]	TCP
streaming multimedia	HTTP (eg Youtube), RTP [RFC 1889]	TCP or UDP
Internet telephony	SIP, RTP, proprietary (e.g., Skype)	typically UDP

Segurança ao Nível da Aplicação (1/2)

- Atualmente, vários serviços empresariais são oferecidos através de aplicações cliente-servidor. As formas mais populares são as aplicações Web e o correio eletrónico. Em ambas as aplicações, o cliente comunica com um servidor e obtém serviços.
- Ao utilizar um serviço de qualquer aplicação servidor, o cliente e o servidor trocam muitas informações na intranet ou na Internet subjacente. Além disso, sabemos que estas transações de informação são vulneráveis a vários ataques.
- Foram desenvolvidos vários protocolos de segurança para esta camada, ainda assim é necessário conseguir cumprir determinados objetivos, tais como:
 - As partes puderem negociar interactivamente a autenticação mútua;
 - Estabelecer uma chave de sessão secreta antes de serem trocadas informações na rede;
 - Trocar as informações de forma encriptada.

Segurança ao Nível da Aplicação (2/2)

- É curioso constatar que estes protocolos funcionam em diferentes níveis do modelo de rede. Por exemplo, o protocolo S/MIME funciona na camada de aplicação, o protocolo SSL foi desenvolvido para funcionar na camada de transporte e o protocolo IPsec funciona na camada de rede.

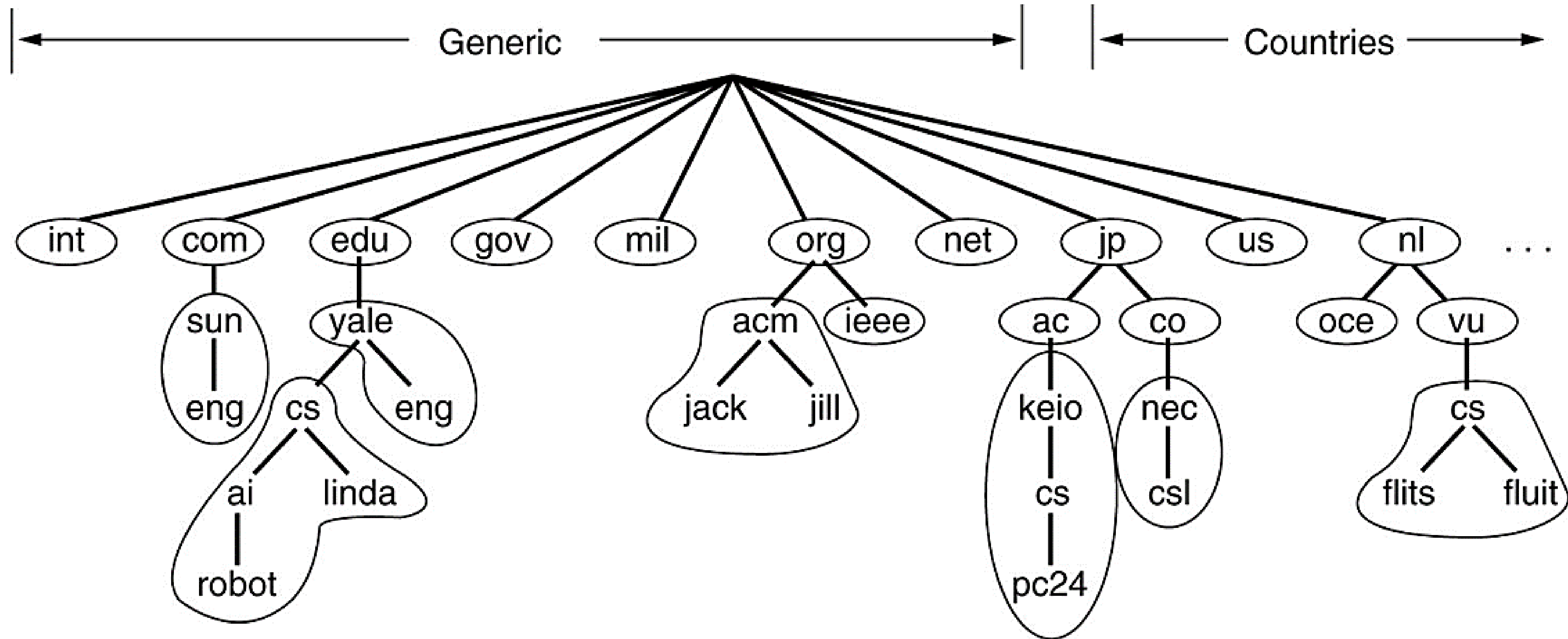


Domain Name System (DNS)

- Gere a conversão entre IP e nome (UDP, TCP porto 53)
- Base de dados hierárquica distribuída entre vários servidores
 - Escalabilidade, não existe ponto único de falha
- 13 servidores partilham a responsabilidade pela raiz (*Root Servers*)
- *Top level domains* (TLD) são responsáveis pelo com, edu, org, etc
- Servidores autoritários são responsáveis pelo domínio controlado
 - 1 primário que aceita alterações ao domínio e propaga para 1 ou vários secundários que não aceitam alterações diretas
- *Resolvers* são servidores locais para fazer pedidos DNS e fazer *caching* de nomes

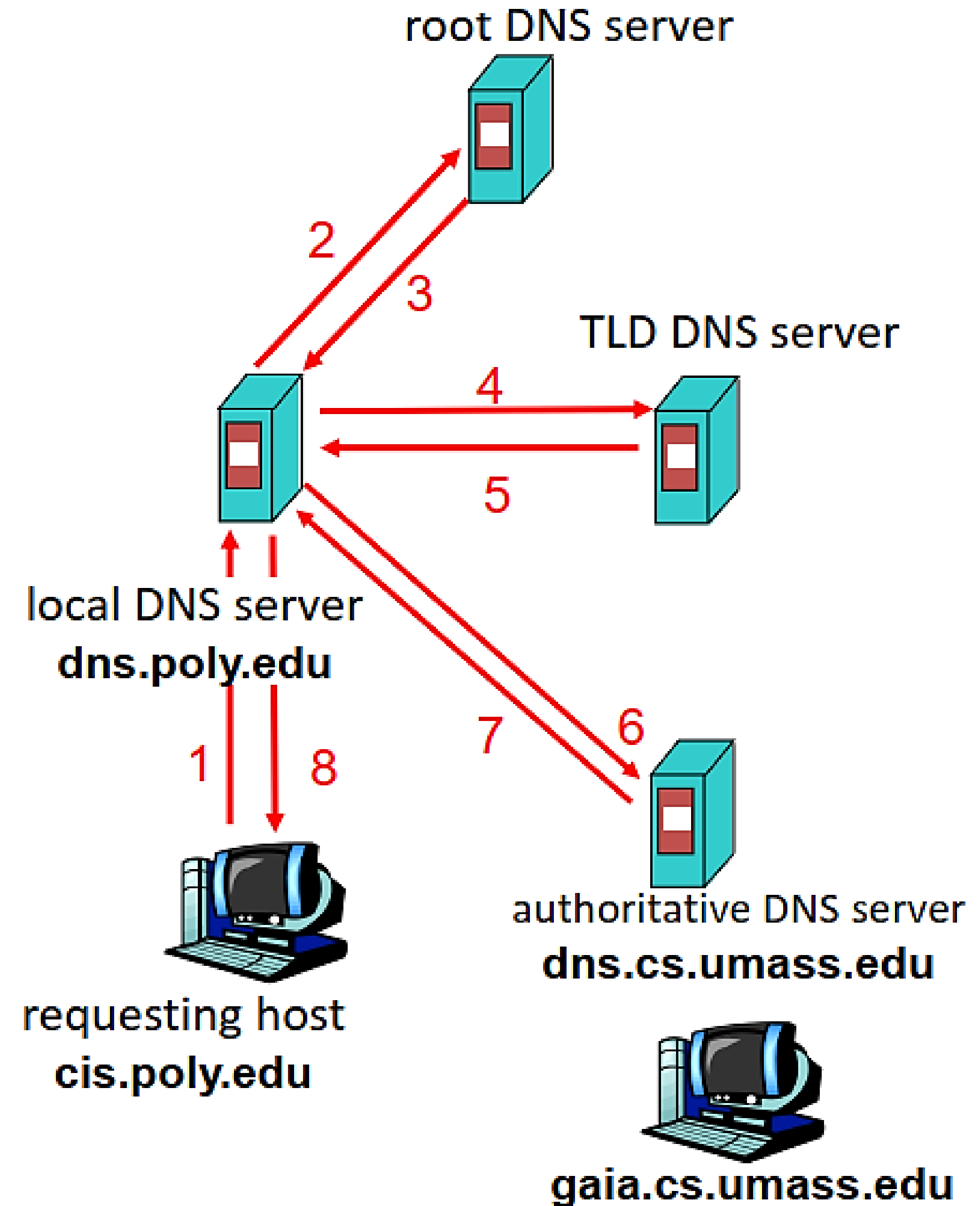


Hierarquia de servidores DNS



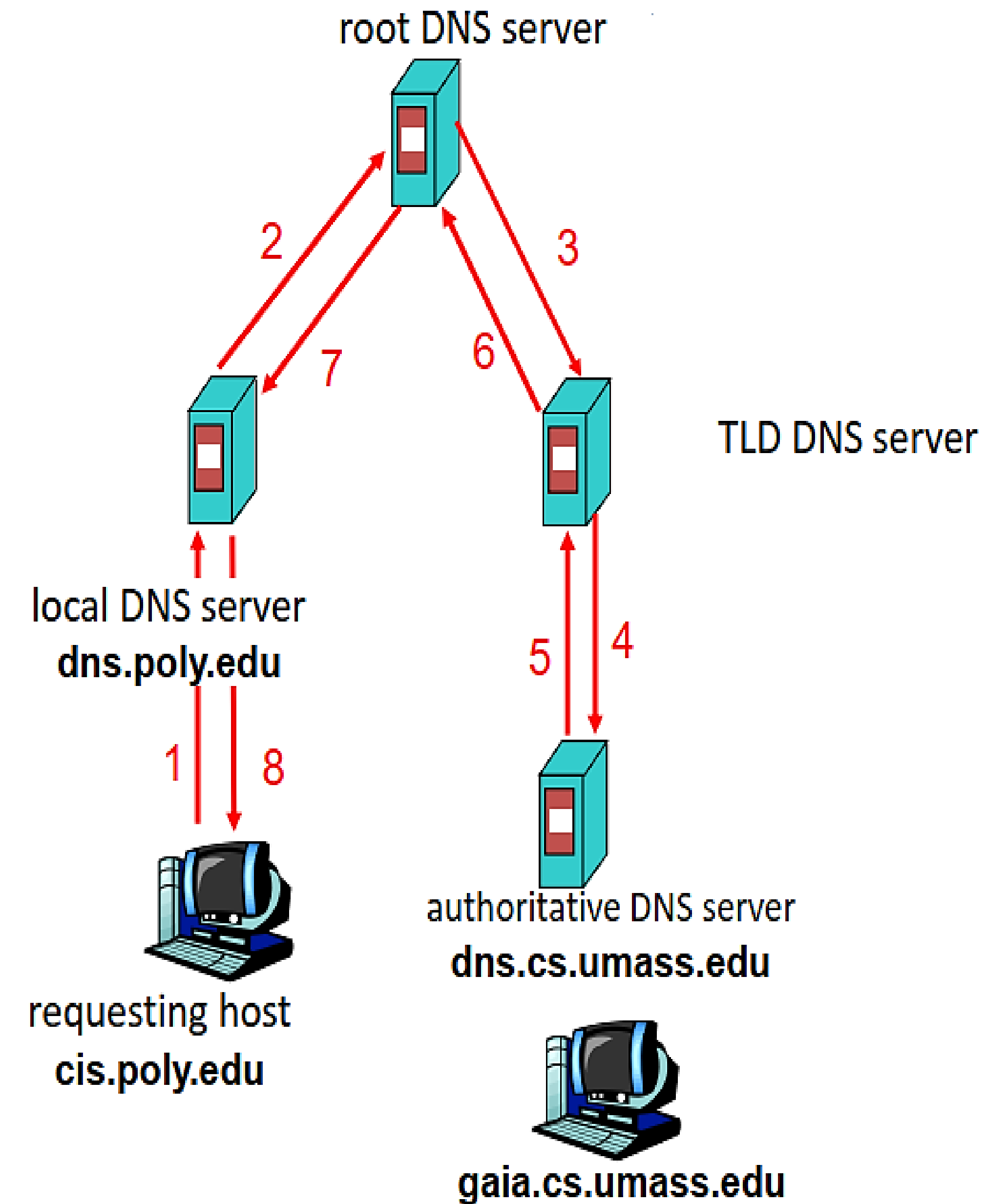
Querys DNS (1/2)

- Num esquema DNS normal, sempre que o utilizador pretende ligar-se a qualquer nome de domínio, o seu computador contacta o servidor DNS e procura o endereço IP associado a esse nome de domínio. Uma vez obtido o endereço IP, o computador liga-se a esse endereço IP.
- Neste esquema, não há qualquer processo de verificação envolvido. Um computador pede ao seu servidor DNS o endereço associado a um *website*, o servidor DNS responde com um endereço IP e o seu computador aceita-o, sem qualquer dúvida, como uma resposta legítima e liga-se a esse *website*.
- Pedido de cis.poly.edu para obter o ip de gaia.cs.umass.edu
 - Modo *query* iterativa



Querys DNS (2/2)

- Pedido de cis.poly.edu para obter o ip de gaia.cs.umass.edu
 - Modo *query* recursiva



Registos no DNS

- Cada registo de DNS é um *resource record* (RR):
 - Sintaxe RR (nome ,valor, tipo, TTL)
 - Várias tipologias

Type	Meaning	Value
SOA	Start of Authority	Parameters for this zone
A	IP address of a host	32-Bit integer
MX	Mail exchange	Priority, domain willing to accept e-mail
NS	Name Server	Name of a server for this domain
CNAME	Canonical name	Domain name
PTR	Pointer	Alias for an IP address
HINFO	Host description	CPU and OS in ASCII
TXT	Text	Uninterpreted ASCII text

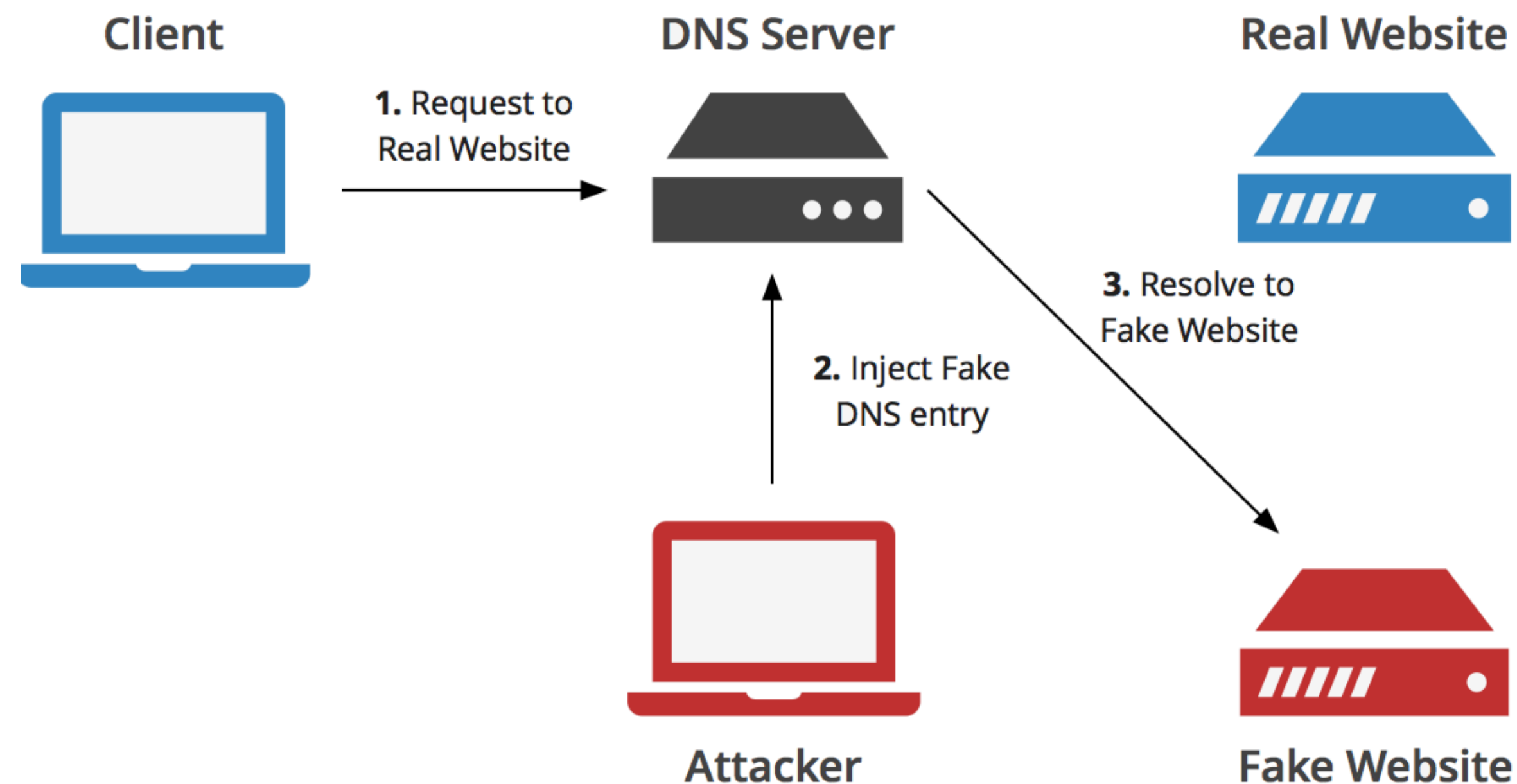
Ataques ao Nível do DNS (1/4)

- **Ataques DoS, DDoS e de amplificação de DNS:**
 - Ao inundar as redes com o que parece ser tráfego legítimo, os ataques de negação de serviço (DoS) e de negação de serviço distribuída (DDoS) aos sistemas DNS podem tornar os *websites* inacessíveis. Além disso tornam indisponíveis os servidores DNS que fornecem o acesso para os utilizadores legítimos.
 - É assim que funciona a amplificação do DNS. O DNS utiliza o protocolo UDP para transportar informações. Um atacante pode falsificar o endereço de origem de um pedido DNS e direccionar a resposta para um endereço IP específico. Isto deve-se ao facto de poderem tirar partido da forma como o UDP envia pacotes de dados através da Internet. Além disso, as respostas DNS são por vezes maiores do que os pedidos correspondentes. Ao submeter um pequeno pedido a um servidor DNS e enviar uma grande resposta ao alvo, os atacantes DDoS podem aumentar ou "amplificar" as suas operações.

Ataques ao Nível do DNS (2/4)

- **DNS Spoofing:**

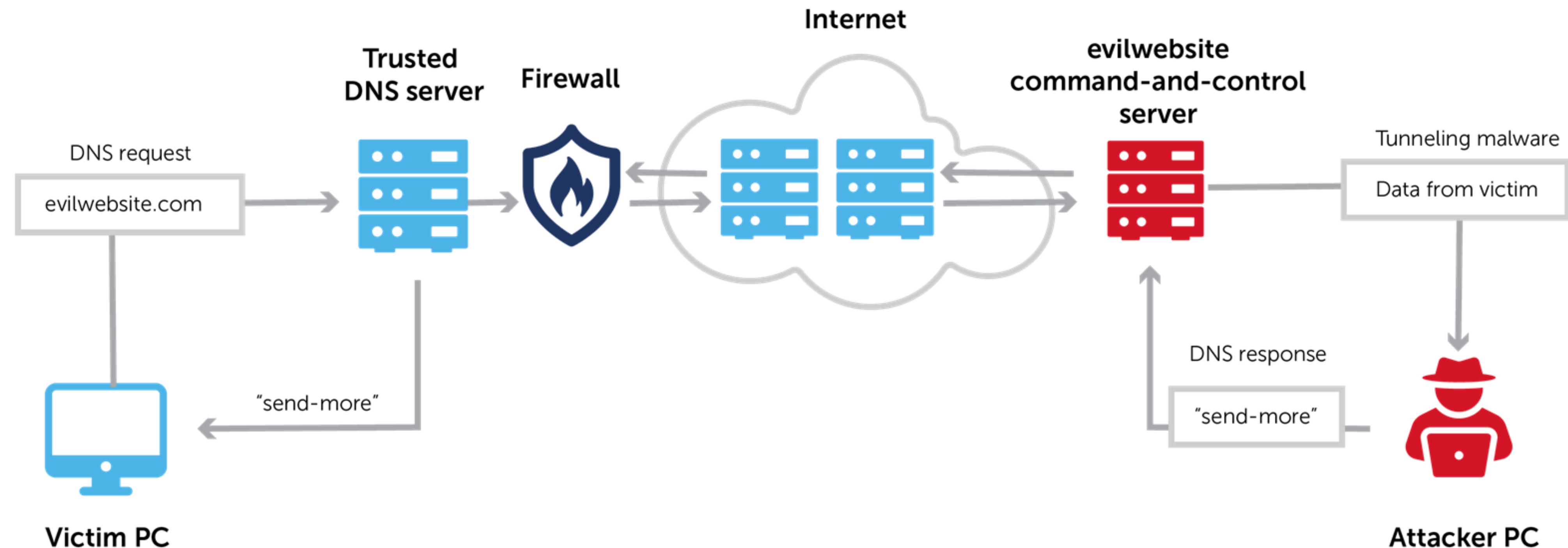
- Num cenário de *DNS spoofing*, são enviados dados DNS falsos para a cache do *DNS resolver*, fazendo com que este comunique um endereço IP falso. O tráfego será redirecionado para um domínio malicioso. Como resultado, o endereço do *website* pode ser utilizado para fins maliciosos, como a distribuição de vírus ou o roubo de credenciais de início de sessão.



Ataques ao Nível do DNS (3/4)

- **DNS Tunneling:**

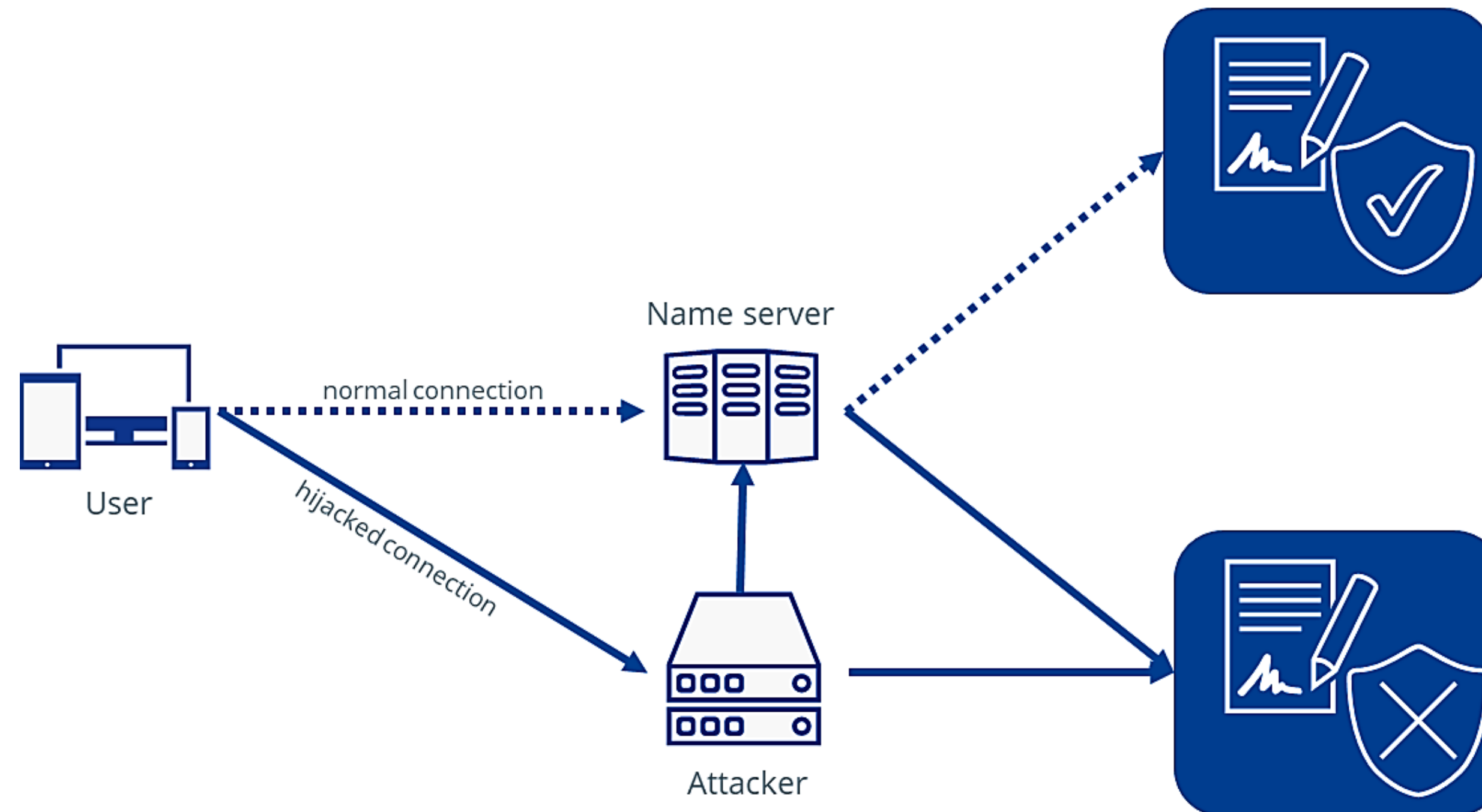
- O *DNS tunneling* utiliza um modelo cliente-servidor para transportar *malware* e outros dados através do protocolo DNS. O *malware* utilizado para o tráfego de *tunneling* é colocado no servidor do atacante. Quando o servidor do alvo se liga ao *website* do atacante, o *malware* é transmitido, criando um túnel entre o *website* malicioso e o DNS.



Ataques ao Nível do DNS (4/4)

- **DNS Hijacking:**

- O sequestro de DNS refere-se a qualquer ataque que engane um utilizador, levando-o a crer que está a ligar-se a um domínio de confiança, embora na realidade esteja ligado a um website malicioso. Isto pode ser feito enganando um servidor DNS para que armazene dados DNS incorretos ou utilizando um servidor DNS comprometido ou malicioso.

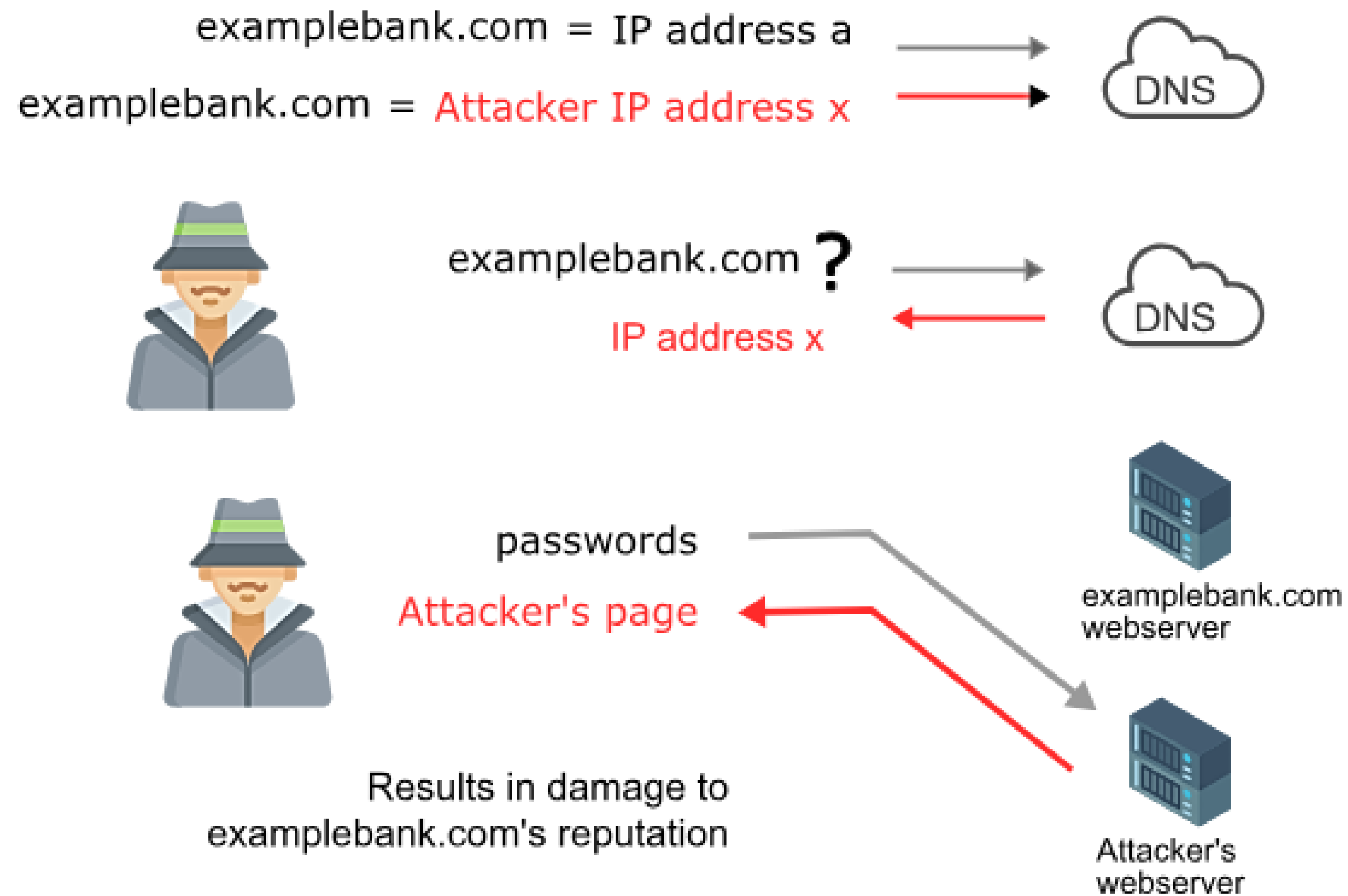


DNSSEC (1/2)

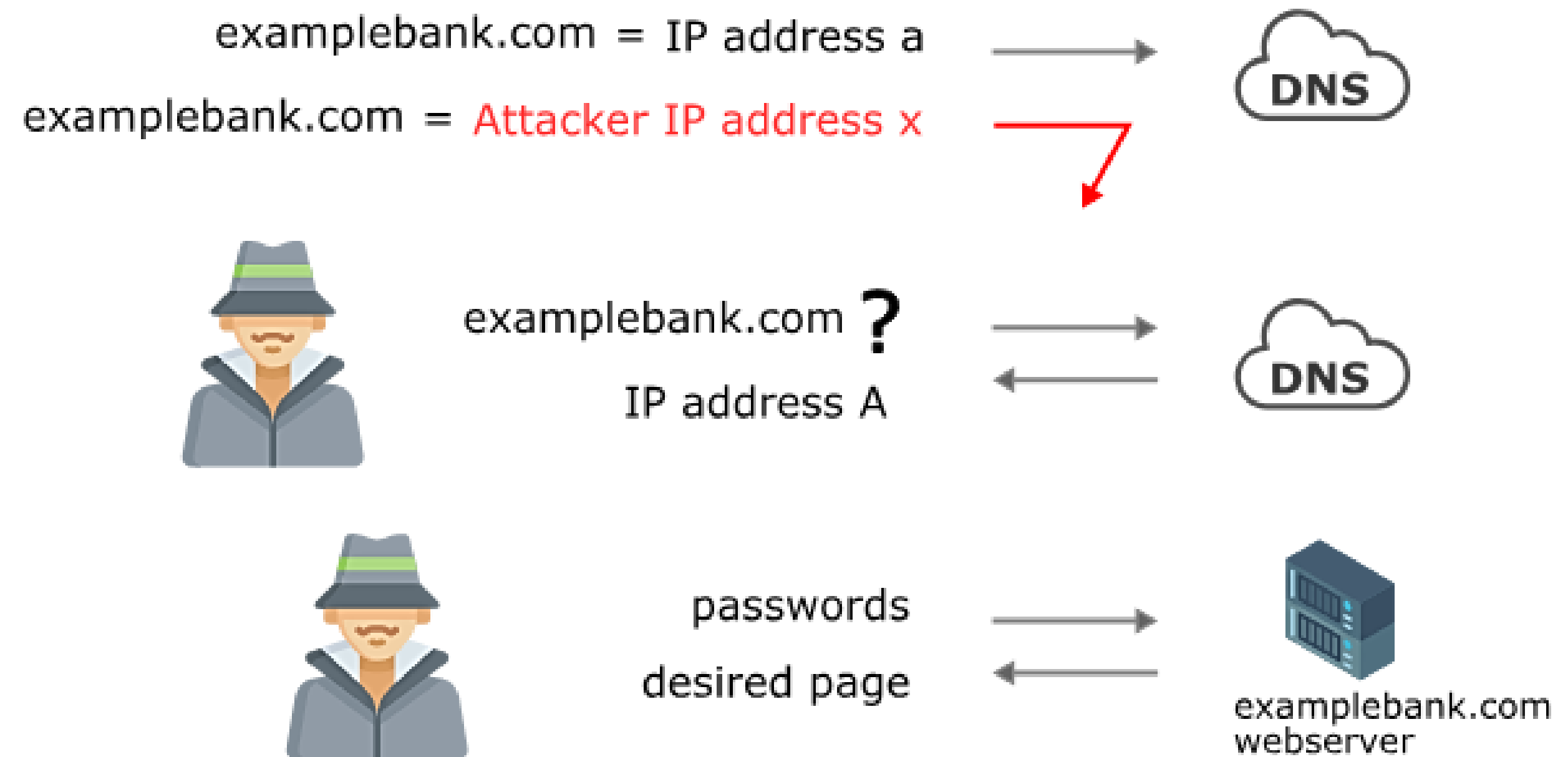
- O *DNS lookup*, quando efetuado com DNSSEC, envolve a assinatura das respostas pela entidade que responde. O DNSSEC baseia-se na criptografia de chave pública.
- Na norma DNSSEC, cada zona DNS tem um par de chaves pública/privada. Todas as informações enviadas por um servidor DNS são assinadas com a chave privada da zona de origem para garantir a autenticidade. Os clientes DNS precisam de conhecer as chaves públicas da zona para verificar as assinaturas. Os clientes podem ser pré-configurados com as chaves públicas de todos os domínios de topo, ou *root DNS*.

DNSSEC (2/2)

Without DNSSEC



With DNSSEC

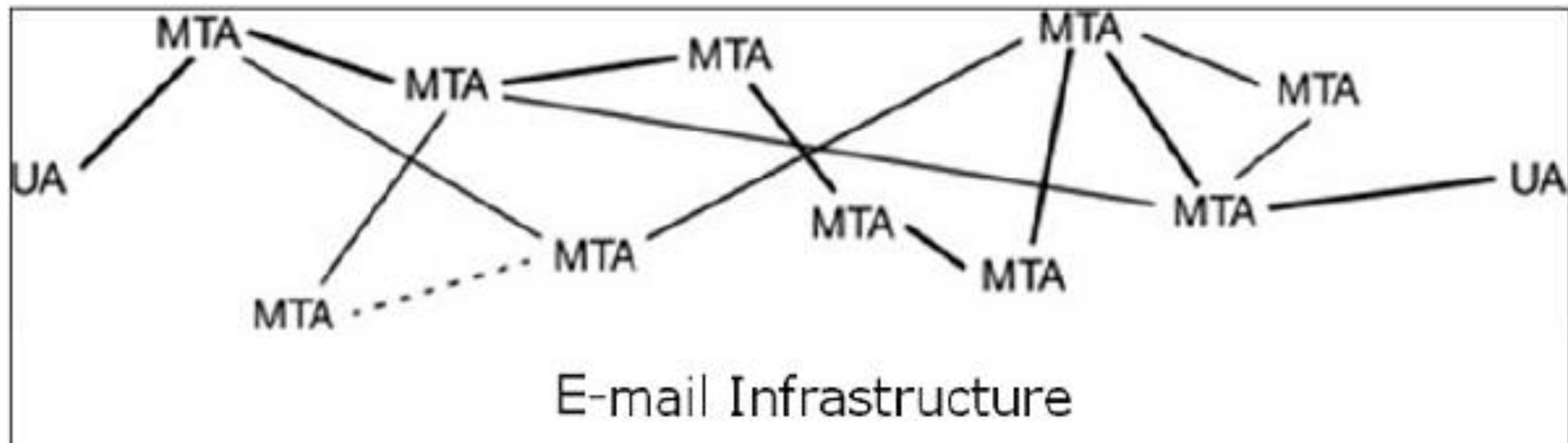


Infraestrutura de Correio Eletrónico (1/2)

- A forma mais simples de enviar uma mensagem de correio eletrónico consiste em enviar uma mensagem diretamente da máquina do remetente para a máquina do destinatário. Neste caso, é essencial que ambas as máquinas estejam a funcionar em simultâneo na rede. No entanto, esta configuração não é prática, uma vez que os utilizadores podem ocasionalmente ligar as suas máquinas à rede.
- Assim, surgiu o conceito de criação de servidores de correio eletrónico. Nesta configuração, o correio é enviado para um servidor de correio eletrónico que está permanentemente disponível na rede. Quando a máquina do destinatário se liga à rede, lê o correio do servidor de correio.

Infraestrutura de Correio Eletrónico (2/2)

- Em geral, a infraestrutura de correio eletrónico é constituída por uma rede de servidores de correio, também designados por Message Transfer Agents (MTA), e por máquinas clientes que executam um programa de correio eletrónico que inclui o User Agent (UA) e o MTA local. Normalmente, uma mensagem de correio eletrónico é reencaminhada do seu UA, passa pela malha de MTA e chega finalmente ao UA na máquina do destinatário.



Protocolos de Correio Eletrónico

- Os protocolos utilizados para o correio eletrónico são:
 - **Simple mail Transfer Protocol (SMTP)** - utilizado para reencaminhar mensagens de correio eletrónico.
 - **Post Office Protocol (POP)** e o **Internet Message Access Protocol (IMAP)** são utilizados para recuperar as mensagens do servidor por destinatário.

MIME

- A norma básica de correio eletrónico da Internet foi escrita em 1982 e descreve o formato das mensagens de correio eletrónico trocadas na Internet. Suporta principalmente mensagens de correio eletrónico escritas como texto em alfabeto romano básico.
- Em 1992, sentiu-se a necessidade de a melhorar. Assim, foi definida uma norma adicional, Multipurpose Internet Mail Extensions (MIME). Trata-se de um conjunto de extensões da norma básica de correio eletrónico da Internet. O MIME permite enviar correio eletrónico utilizando caracteres diferentes dos do alfabeto romano básico, como o alfabeto cirílico (utilizado em russo), o alfabeto grego ou mesmo os caracteres ideográficos do chinês.
- Outra necessidade satisfeita pelo MIME é o envio de conteúdos não textuais, como imagens ou clips de vídeo. Devido a estas características, a norma MIME foi amplamente adotada com o SMTP para a comunicação por correio eletrónico.

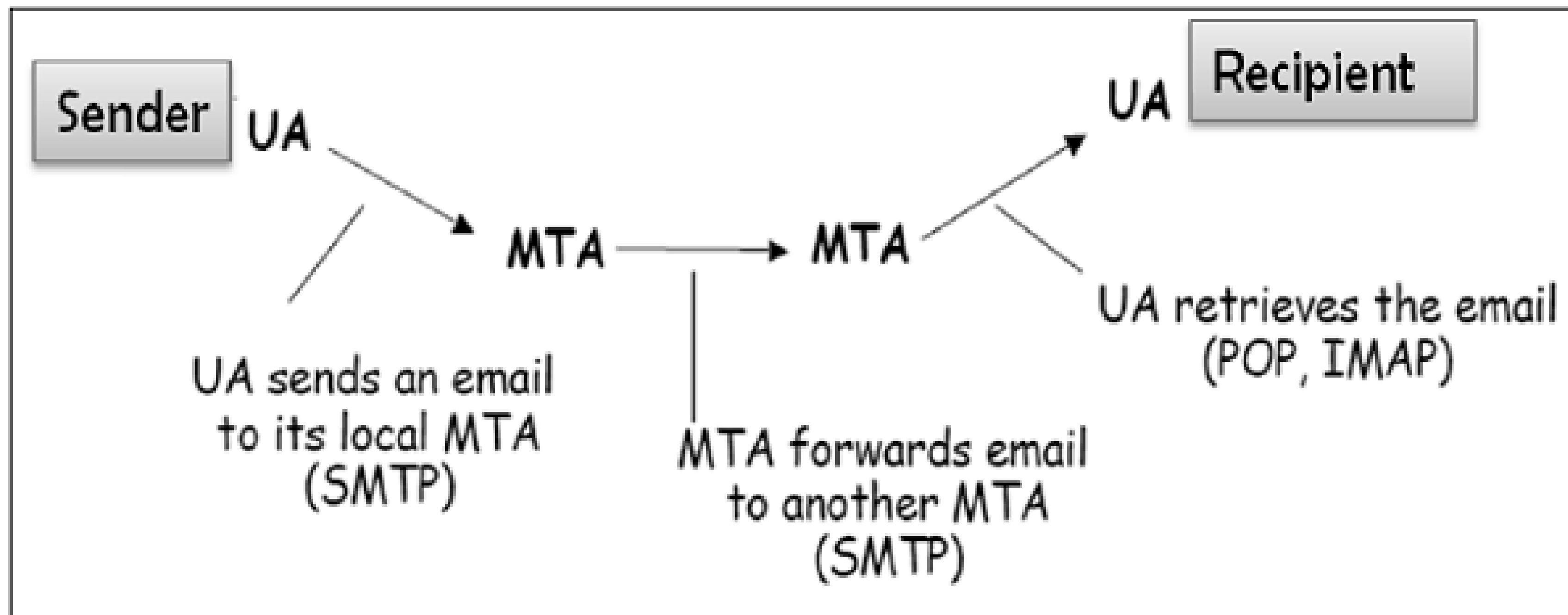
Serviços de Segurança de Correio Eletrónico

criptografia de chave pública

- A utilização crescente da comunicação por correio eletrónico para transações importantes e cruciais exige a prestação de determinados serviços de segurança fundamentais, tais como:
 - **Confidencialidade** - A mensagem de correio eletrónico não deve ser lida por ninguém, exceto pelo destinatário pretendido.
 - **Autenticação** - O destinatário do correio eletrónico pode ter a certeza da identidade do remetente.
 - **Integridade** - Garantia para o destinatário de que a mensagem de correio eletrónico não foi alterada desde que foi transmitida pelo remetente.
 - **Não repúdio** - O destinatário da mensagem de correio eletrónico pode provar a terceiros que o remetente enviou efetivamente a mensagem.
 - **Prova de envio** - O remetente do correio eletrónico obtém a confirmação de que a mensagem foi entregue ao sistema de entrega de correio.
 - **Prova de entrega** - O remetente recebe uma confirmação de que o destinatário recebeu a mensagem.

One-to-One E-mail (1/4)

- Neste cenário, o remetente envia uma mensagem de correio eletrónico para apenas um destinatário. Normalmente, não estão envolvidos mais de dois MTA na comunicação.

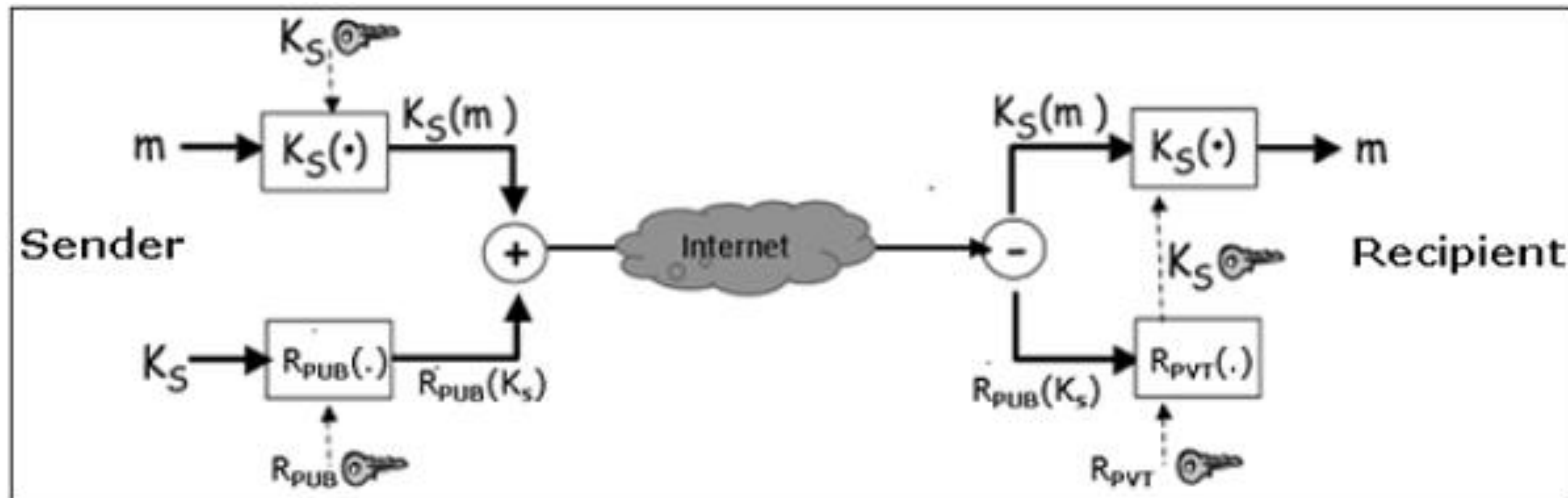


One-to-One E-mail (2/4)

- Suponhamos que um remetente pretende enviar uma mensagem de correio eletrónico confidencial a um destinatário. A garantia de privacidade neste caso é conseguida da seguinte forma:
 - 1) O remetente e o destinatário têm as suas chaves privadas e públicas como (SPVT, SPUB) e (RPVT, RPUB), respetivamente.
 - 2) O emissor gera uma chave simétrica secreta, KS, para encriptação. Embora o emissor pudesse ter utilizado RPUB para a cifragem, é utilizada uma chave simétrica para conseguir uma cifragem e uma decifragem mais rápidas.
 - 3) O remetente cifra a mensagem com a chave KS e também cifra a KS com a chave pública do destinatário, RPUB.
 - 4) O remetente envia a mensagem cifrada e a chave cifrada KS ao destinatário.
 - 5) O destinatário obtém primeiro a KS decifrando a KS codificada com a sua chave privada, RPVT.
 - 6) Em seguida, o destinatário decifra a mensagem utilizando a chave simétrica, KS.

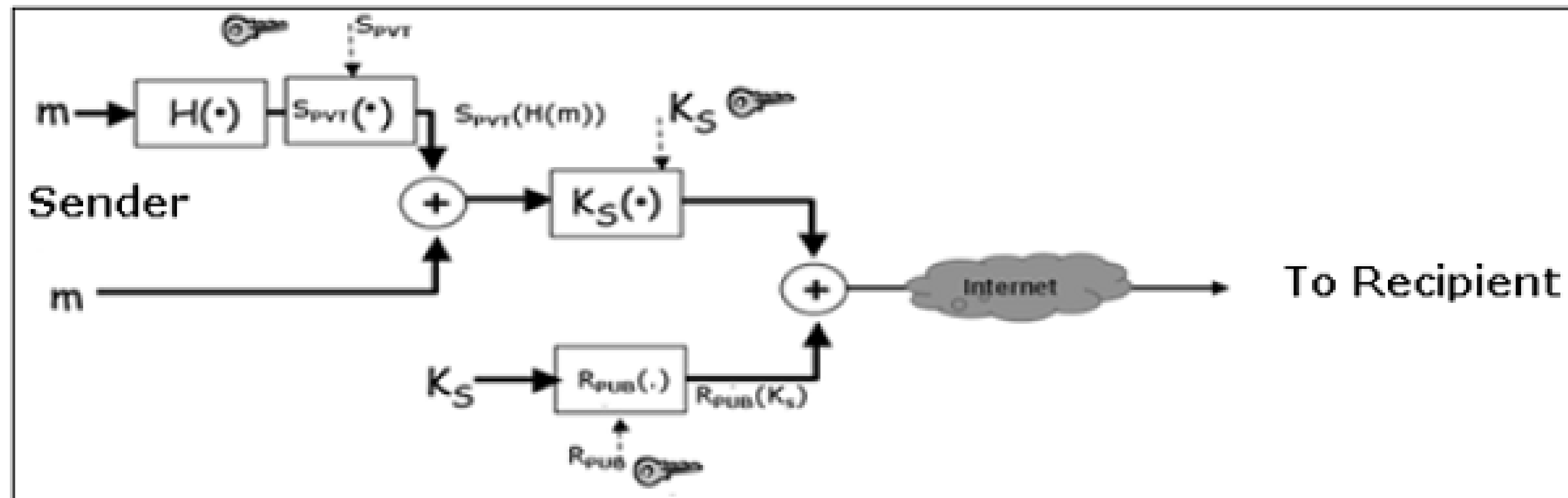
One-to-One E-mail (3/4)

- Se, neste cenário, forem também necessários serviços de integridade, autenticação e não repúdio da mensagem, são acrescentados os seguintes passos ao processo.
- O remetente produz um *hash* da mensagem e assina-o digitalmente com a sua chave privada, SPVT.
- O remetente envia este *hash* assinado para o destinatário juntamente com outros componentes.



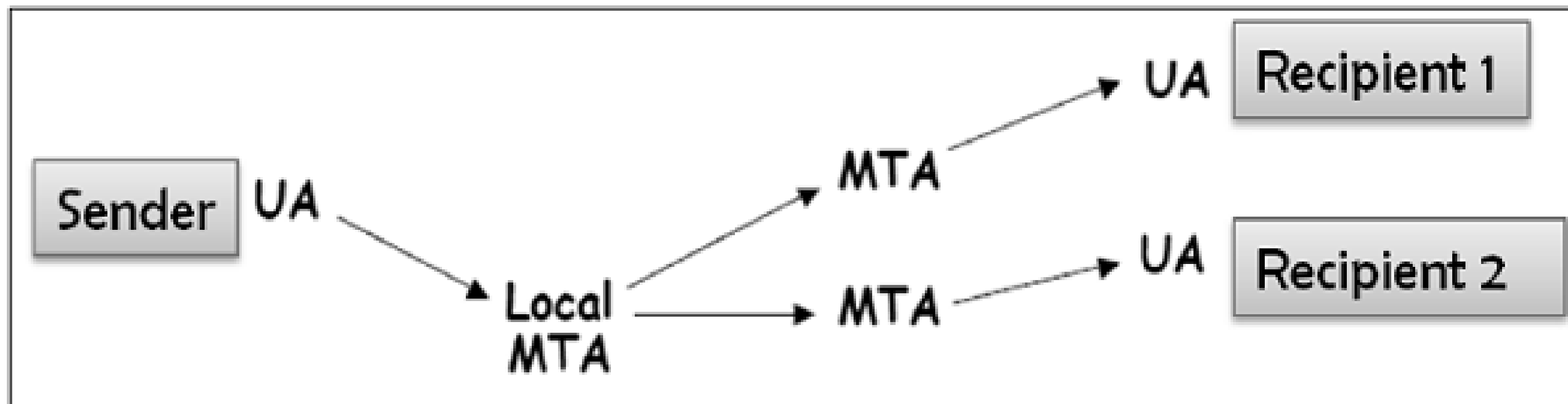
One-to-One E-mail (4/4)

- O destinatário utiliza a chave pública SPUB e extrai o *hash* recebido sob a assinatura do remetente.
- O destinatário efetua então o *hash* da mensagem descriptada e compara os dois valores *hash*. Se coincidirem, considera-se que a integridade da mensagem foi alcançada.
- Além disso, o destinatário tem a certeza de que a mensagem foi enviada pelo remetente (autenticação). E, por último, o remetente não pode negar que não enviou a mensagem (não repúdio).



One-to-Multiple Recipients E-mail (1/2)

- Neste cenário, o remetente envia uma mensagem de correio eletrónico a dois ou mais destinatários. A lista é gerida pelo programa de correio eletrónico do remetente (UA + MTA local). Todos os destinatários recebem a mesma mensagem.

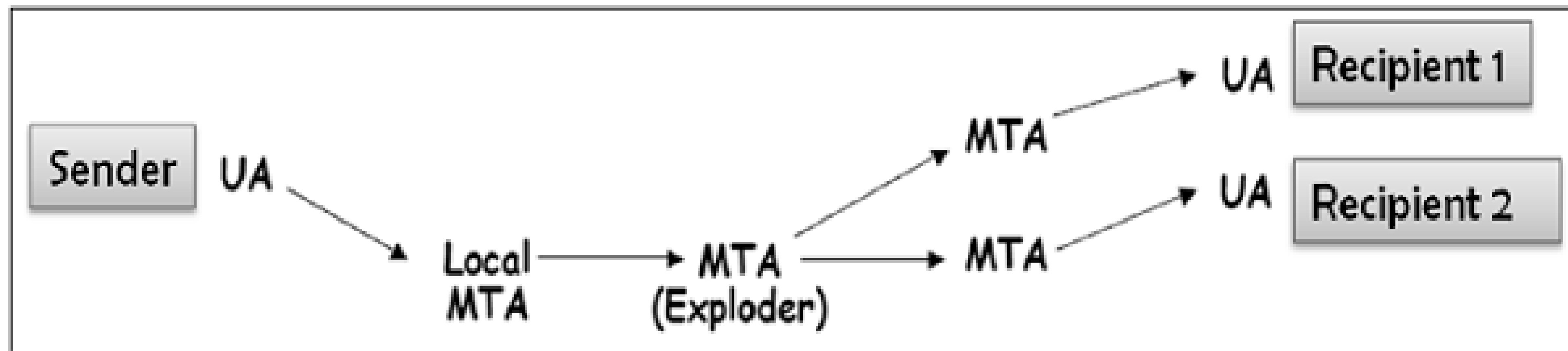


One-to-Multiple Recipients E-mail (2/2)

- Suponhamos que o remetente quer enviar uma mensagem de correio eletrônico confidencial a muitos destinatários (digamos R1, R2 e R3). O fornecimento de privacidade neste caso é conseguido da seguinte forma:
 - 1) O remetente e todos os destinatários têm o seu próprio par de chaves privadas-públicas.
 - 2) O remetente gera uma chave simétrica secreta, K_s , e cifra a mensagem com essa chave.
 - 3) O remetente encripta então K_s várias vezes com as chaves públicas de R1, R2 e R3, obtendo $R1PUB(K_s)$, $R2PUB(K_s)$ e $R3PUB(K_s)$.
 - 4) O remetente envia a mensagem encriptada e o correspondente K_s encriptado ao destinatário. Por exemplo, o destinatário 1 (R1) recebe a mensagem cifrada e $R1PUB(K_s)$.
 - 5) Cada destinatário começa por extrair a chave K_s , decifrando a K_s codificada com a sua chave privada.
 - 6) De seguida, cada destinatário descripta a mensagem utilizando a chave simétrica, K_s .

One-to-Distribution List E-mail (1/4)

- Neste cenário, o remetente envia uma mensagem de correio eletrónico a dois ou mais destinatários, mas a lista de destinatários não é gerida localmente pelo remetente. Geralmente, o servidor de correio eletrónico (MTA) mantém a lista de destinatários.
- O remetente envia uma mensagem de correio eletrónico para o MTA que gere a lista de endereços e, em seguida, a mensagem é enviada pelo MTA para todos os destinatários da lista.

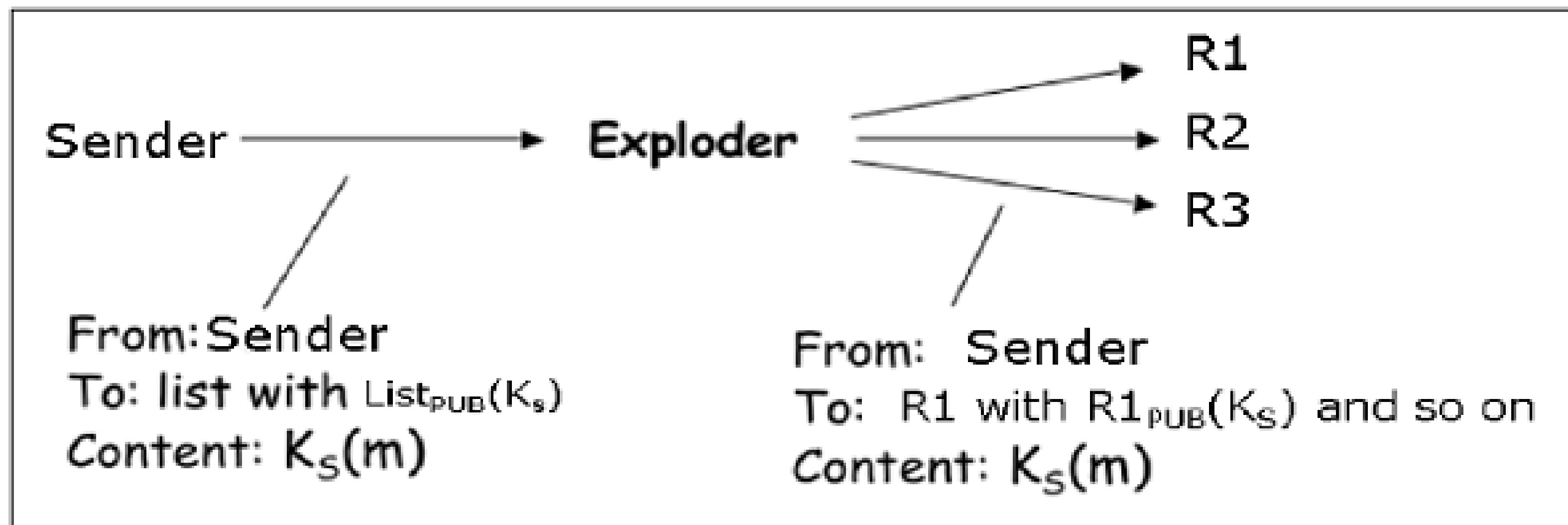


One-to-Distribution List E-mail (2/4)

- Neste caso, quando o remetente pretende enviar uma mensagem de correio eletrónico confidencial aos destinatários da lista de distribuição (digamos, R1, R2 e R3), a privacidade é assegurada da seguinte forma:
 - 1) O remetente e todos os destinatários têm o seu próprio par de chaves privadas-públicas. O servidor Exploder tem um par de chaves privadas-públicas para cada lista de distribuição (ListPUB, ListPVT) mantida por ele.
 - 2) O remetente gera uma chave simétrica secreta K_s e encripta a mensagem com esta chave.
 - 3) O remetente encripta então K_s com a chave pública associada à lista, obtendo ListPUB(K_s).

One-to-Distribution List E-mail (3/4)

- 4) O remetente envia a mensagem cifrada e $\text{ListPUB}(K_S)$. O MTA explorador decifra $\text{ListPUB}(K_S)$ utilizando ListPVT e obtém K_S .
- 5) O exploder encripta K_S com tantas chaves públicas quantos os membros da lista.
- 6) O Explodidor reencaminha a mensagem cifrada recebida e o correspondente K_S cifrado para todos os destinatários da lista. Por exemplo, o Explodidor reencaminha a mensagem cifrada e o $R1\text{PUB}(K_S)$ para o destinatário 1 e assim sucessivamente.



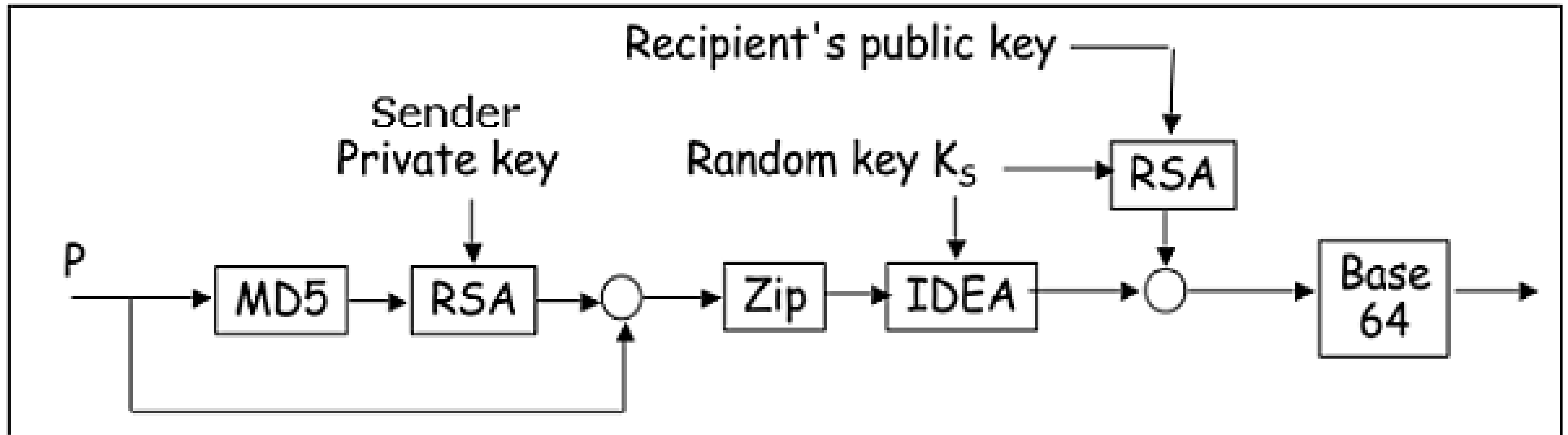
One-to-Distribution List E-mail (4/4)

- Para garantir a integridade, a autenticação e o não repúdio da mensagem, os passos a seguir são semelhantes aos dados no caso de um cenário de correio eletrónico individual.
- É interessante notar que o programa de correio eletrónico que emprega o método de segurança acima descrito para proteger a mensagem de correio eletrónico deverá funcionar em todos os cenários possíveis acima referidos. A maior parte dos mecanismos de segurança acima referidos para o correio eletrónico são fornecidos por dois esquemas populares, o Pretty Good Privacy (PGP) e o S/MIME.

Pretty Good Privacy (PGP)

- É um esquema de encriptação de correio eletrónico. Tornou-se a norma para o fornecimento de serviços de segurança para comunicações através do correio eletrónico.
- Tal como referido anteriormente, utiliza criptografia de chave pública, criptografia de chave simétrica, função *hash* e assinatura digital. Fornece:
 - Privacidade
 - Autenticação do remetente
 - Integridade da mensagem
 - Não repúdio
- Juntamente com estes serviços de segurança, também fornece compressão de dados e suporte à gestão de chaves. O PGP utiliza algoritmos criptográficos existentes, tais como RSA, IDEA, MD5, etc.

Funcionamento do PGP (1/2)

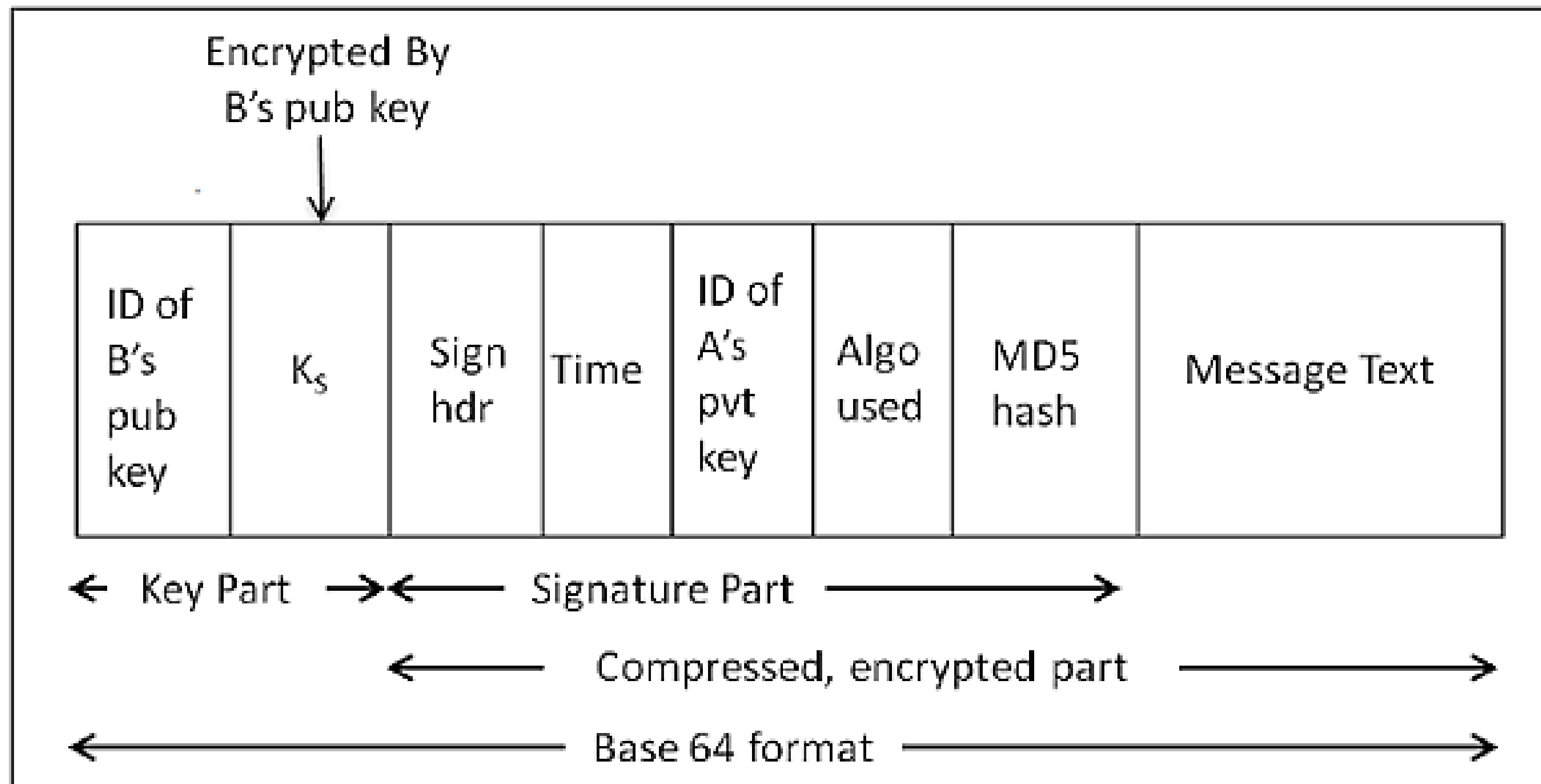


Funcionamento do PGP (2/2)

- 1) O hash da mensagem é calculado. (Algoritmo MD5)
- 2) O hash de 128 bits resultante é assinado utilizando a chave privada do remetente (algoritmo RSA).
- 3) A assinatura digital é concatenada com a mensagem e o resultado é comprimido.
- 4) É gerada uma chave simétrica de 128 bits, KS, que é utilizada para encriptar a mensagem comprimida com IDEA.
- 5) A KS é encriptada com a chave pública do destinatário utilizando o algoritmo RSA e o resultado é anexado à mensagem encriptada.

Formato de mensagem do PGP

- O formato da mensagem PGP é apresentado no diagrama seguinte. Os IDs indicam qual a chave utilizada para encriptar K_S e qual a chave a utilizar para verificar a assinatura no *hash*.
- No esquema PGP, uma mensagem é assinada e encriptada e, em seguida, o MIME é codificado antes da transmissão.



Certificado PGP

- O certificado de chave PGP é normalmente estabelecido através de uma cadeia de confiança. Num ambiente PGP, qualquer utilizador pode atuar como uma autoridade de certificação. Qualquer utilizador do PGP pode certificar a chave pública de outro utilizador do PGP. No entanto, esse certificado só é válido para outro utilizador se este reconhecer o certificador como um introdutor de confiança.
- Existem vários problemas com este método de certificação. Pode ser difícil encontrar uma cadeia que conduza de uma chave pública conhecida e fiável à chave desejada. Além disso, podem existir várias cadeias que podem conduzir a diferentes chaves para o utilizador pretendido. O PGP também pode utilizar a infraestrutura PKI com autoridade de certificação e as chaves públicas podem ser certificadas pela CA (certificado X.509).

S/MIME (1/3)

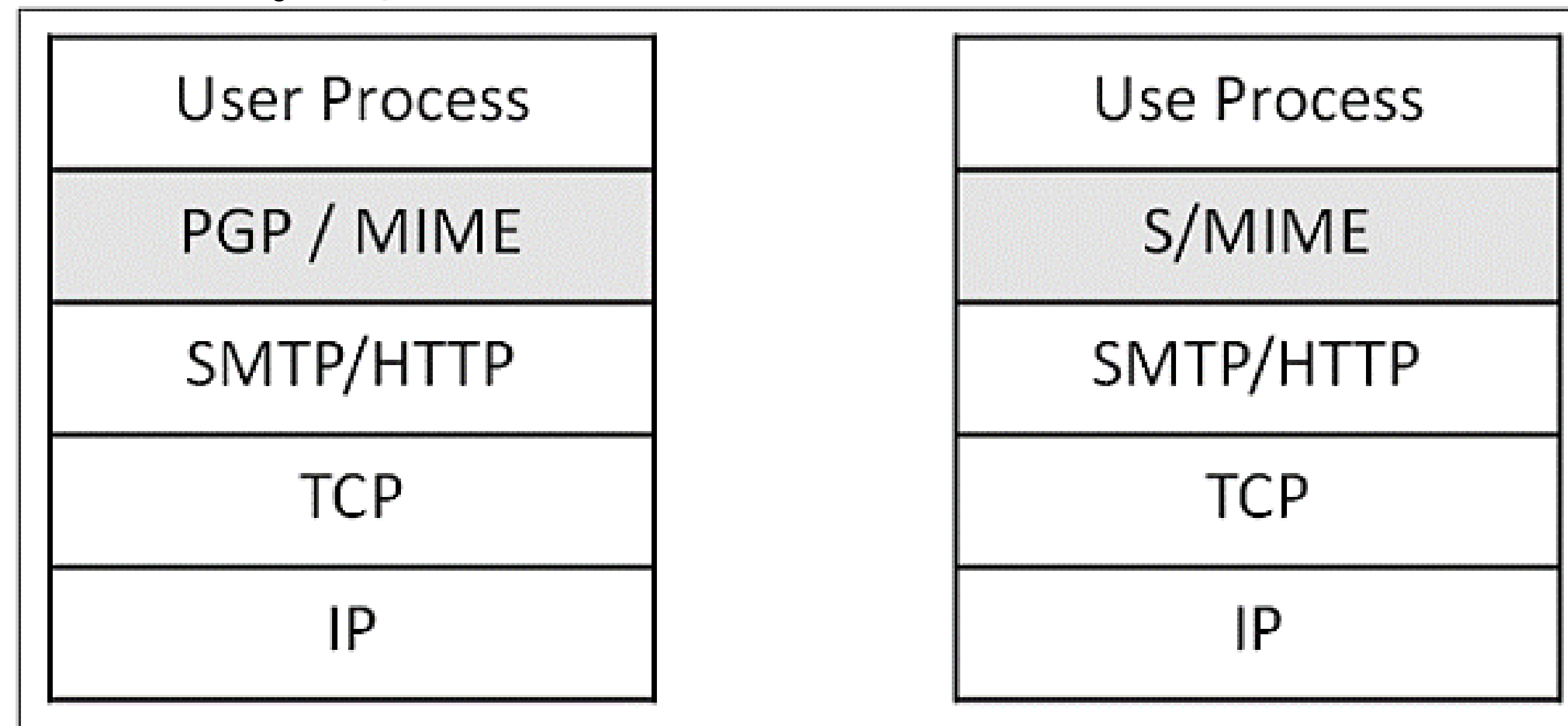
- O termo S/MIME significa Secure Multipurpose Internet Mail Extension. A S/MIME é uma norma de correio eletrónico seguro e baseia-se numa norma anterior de correio eletrónico não seguro denominada MIME.
- A abordagem S/MIME é semelhante à do PGP. Também utiliza criptografia de chave pública, criptografia de chave simétrica, funções de *hash* e assinaturas digitais. Caracteriza-se por fornecer serviços de segurança semelhantes aos do PGP para a comunicação através do correio eletrónico. As cifras simétricas mais comuns utilizadas no S/MIME são RC2 e TripleDES. O método de chave pública habitual é o RSA e o algoritmo de hashing é o SHA-1 ou o MD5.
- O S/MIME especifica o tipo MIME adicional, tal como "application/pkcs7-mime", para a inclusão de dados após a cifragem. Toda a entidade MIME é cifrada e empacotada num objeto. O S/MIME tem formatos de mensagem criptográfica normalizados (diferente do PGP).

S/MIME (2/3)

- De facto, o MIME é alargado com algumas palavras-chave para identificar as partes cifradas e/ou assinadas da mensagem. O S/MIME baseia-se em certificados X.509 para a distribuição de chaves públicas, ainda assim necessita de uma PKI hierárquica descendente para suporte da certificação.
- Devido ao requisito de um certificado da autoridade de certificação para a implementação, nem todos os utilizadores podem tirar partido do S/MIME, uma vez que alguns podem desejar cifrar uma mensagem com um par de chaves públicas/privadas. Por exemplo, sem o envolvimento ou a sobrecarga administrativa dos certificados.
- Na prática, embora a maioria das aplicações de correio eletrónico implemente o S/MIME, o processo de registo de certificados é complexo. Em vez disso, o suporte do PGP requer normalmente a adição de um plug-in e esse plug-in vem com tudo o que é necessário para gerir chaves. As pessoas trocam as suas chaves públicas através de outro meio. Uma vez obtidas, guardam uma cópia das chaves públicas das pessoas com quem trocam mensagens de correio eletrónico.

S/MIME (3/3)

- A camada de implementação na arquitetura de rede para os esquemas PGP e S/MIME é apresentada na imagem seguinte. Estes dois esquemas fornecem segurança a nível da aplicação para a comunicação por correio eletrónico.



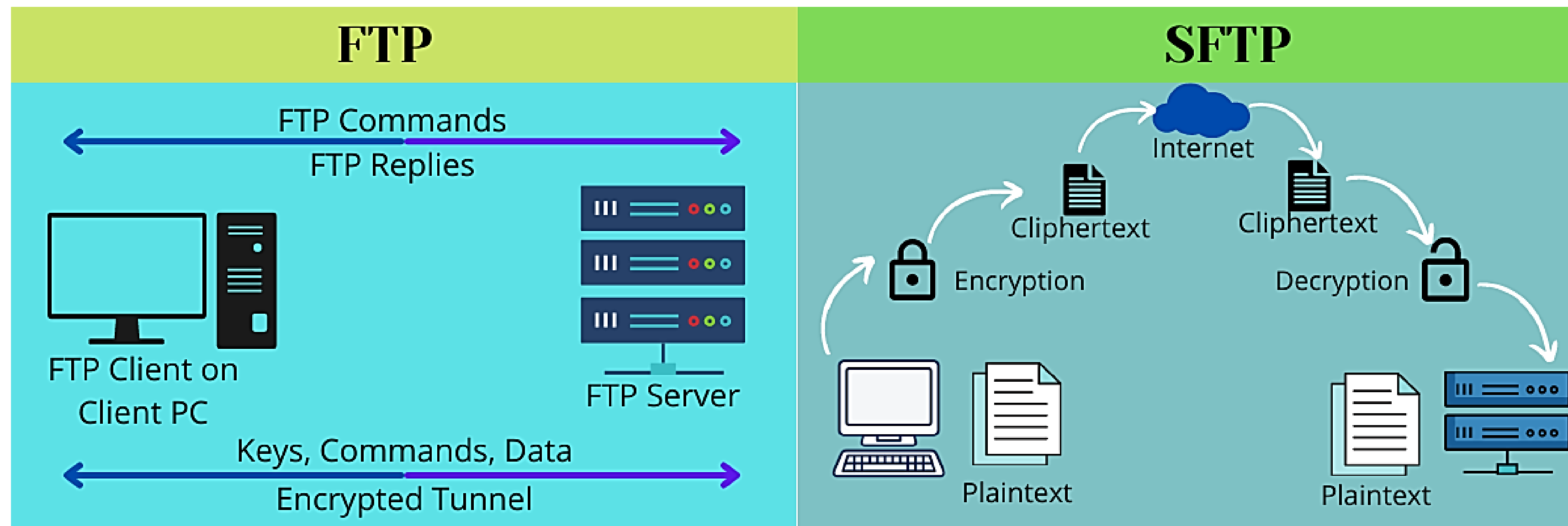
- O PGP ou o S/MIME, é utilizado consoante o ambiente. Para a segurança do correio eletrónico na Internet, em que é frequente a troca de mensagens com novos utilizadores desconhecidos, o S/MIME é considerado uma boa opção.

Transferência Segura de Ficheiros (1/2)

- A transferência segura de ficheiros é algo de extrema importância tendo em conta as vulnerabilidades associadas ao File Transfer Protocol (FTP). Como resposta a estes requisitos foi concebido o Secure File Transfer Protocol (SFTP) que permite aceder, transferir e gerir de forma segura ficheiros de grandes dimensões e dados sensíveis.
- Concebido pela Internet Engineering Task Force como uma extensão do Secure Shell (SSH), o SFTP permite o acesso, a transferência e a gestão de ficheiros através de uma rede. É utilizado para transferências seguras de ficheiros através do Transport Layer Security (TLS) e para a transferência de dados para aplicações de redes privadas virtuais (VPN).
- O SFTP ajuda as empresas a cumprir os regulamentos de conformidade de transferência de ficheiros de acordo com o RGPD e outras normas regulamentares. O SFTP também permite que as empresas transfiram de forma segura dados de faturação, fundos e ficheiros de recuperação de dados. Os particulares também podem utilizar o SFTP para encriptar as suas comunicações.

Transferência Segura de Ficheiros (1/2)

- O SFTP utiliza SSH para transferir ficheiros e requer que o cliente seja autenticado pelo servidor. Os comandos e os dados são encriptados para evitar que as palavras-passe e outras informações sensíveis sejam expostas à rede em texto simples.



Aspectos Diferenciadores entre FTP e SFTP

- **Segurança** – enquanto o FTP não é encriptado, o SFTP encripta os dados antes de os enviar para um *host*;
- **Arquitetura** – enquanto o FTP funciona numa arquitetura cliente-servidor, o SFTP funciona numa arquitetura SSH;
- **Portas utilizadas** – enquanto o FTP utiliza a porta 21 para portas de entrada e saída, o SFTP permite ligações de entrada na porta 22;
- **Método de transferência** – enquanto o FTP utiliza transferências diretas, o SFTP utiliza o tunelamento, que pode proteger todos os dados transmitidos e as credenciais de autenticação.

Principais Pontos Fortes do SFTP

- **Segurança** – o SFTP permite a segurança dos dados, a encriptação e a autenticação de chave pública, que protegem os dados em trânsito. A segurança faz do SFTP uma opção fiável de transferência de ficheiros;
- **Velocidade** – o SFTP suporta transferências de ficheiros de grandes dimensões e a transferência simultânea de vários ficheiros de um servidor para outro;
- **Integração** – o SFTP pode ser integrado facilmente com VPNs e *firewalls*;
- **Gestão** – o SFTP pode ser gerido através de uma interface Web ou de um cliente SFTP.

Aspetos a ter em consideração a propósito do uso do SFTP

- **Complexidade** – embora o SFTP seja gerível, o processo de criação e configuração de um cliente SFTP é muito mais complicado do que o processo de criação de um cliente FTP;
- **Armazenamento de chaves privadas** – as chaves privadas SFTP têm de ser armazenadas no dispositivo a partir do qual os utilizadores pretendem transferir ficheiros, e o dispositivo também deve estar protegido;
- **Possíveis problemas de compatibilidade** – as normas relativas ao SFTP são descritas como opcionais e recomendadas, o que pode levar a problemas de compatibilidade com *software* desenvolvido por diferentes fornecedores.

Referências Adicionais acerca dos Temas Abordados

- Livro “James Kurose; Keith Ross. Computer Networking: A Top-Down Approach, Pearson, 2017”:
 - Capítulos 9.1, 9.2 e 9.3
- Livro “William Stallings. Network Security Essentials: Applications and Standards, Pearson, 2016”:
 - Capítulos 7.1 e 7.2



iscte

INSTITUTO
UNIVERSITÁRIO
DE LISBOA